CERTIFICATE OF AUTHORSHIP / ORIGINALITY

I, Yasir Dhaifallah O Alyoubi, declare that this thesis, submitted in fulfilment of the requirements for the award of Doctor of Philosophy, in the School of Computer Science, Faculty of Engineering and Information Technology at the University of Technology Sydney, Australia, is wholly my own work unless otherwise referenced or acknowledged. In addition, I certify that all information sources and literature used are indicated in the thesis. This document has not been submitted for qualifications at any other academic institution. This research is supported by the Australian Government Research Training Program.

Signature of Candidate: Yasir Dhaifallah O Alyoubi

Date:

ACKNOWLEDGEMENT

All praise is due to Allah, Lord of the worlds, who gave me the strength, the patience and the means to reach this point. Every step of this journey was by His grace, and I thank Him first and last.

A thesis is never the work of one person, and when it is finished it is right to look back and thank those who made it possible. My deepest gratitude goes to my supervisor, Professor Farookh Hussain. He accepted me as his student, guided my research from its first idea to its last chapter, corrected me with patience when I was wrong, and encouraged me when I doubted myself. He was more than a supervisor to me; he was a mentor and an elder brother, and his door was always open. Without his support I could not have completed this work.

I also thank my co-supervisor, Dr Firas Al-Doghman, for his guidance, his careful reading of my work and his advice at every stage of this research.

I thank the University of Technology Sydney for giving me the opportunity to study here, for the scholarship that made this research possible, and for the environment, the resources and the people that made it a second home.

Finally, I thank my family. My parents, whose prayers and sacrifices have been with me all my life. My wife, who stood beside me through every long day and night of this journey and carried more than her share so that I could study. My children, who gave me the reason to keep going. And my brothers and sisters, whose support never failed. This thesis is for all of them.

LIST OF PUBLICATIONS

Conference publications

1- 'A Blockchain-Based Framework for Evaluating User Identity Trustworthiness in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

2- 'Blockchain-Based Reputation Borrowing Model to Address the Cold Start Problem for New Users in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

3- 'A Smart Contract-Governed Lifecycle Protocol for Reputation Borrowing in Blockchain-Based Real Estate Platforms', ICEBE 2026. (Accepted)

4- 'A Trusted Multi-Party Consent Governance Framework for Decentralized Multi-Stakeholder Data Sharing', BWCCA 2026. (Accepted)

5- 'Blockchain-Based Reputation Provenance Tracing for Newcomer Bootstrapping in Real Estate', BWCCA 2026. (Accepted)

LIST OF FIGURES

LIST OF TABLES

ABSTRACT

Patient consent is the permission a patient gives for their health data to be used or shared. In most healthcare systems, consent is stored as a record and is checked once, when the permission is first given. After that, access to the data depends on the login of the person asking and on a stored permission in the hospital system. This arrangement does not show whether the person asking is really who they claim to be, whether they have the authority to ask, whether the people who had to agree have all agreed, or whether the consent is still in force at the time of the request.

The problem is harder when the patient cannot decide alone. A child, an elderly patient or a patient without capacity depends on guardians, and in these cases more than one person must agree before the data can be released. Decentralised identifiers (DIDs) and verifiable credentials (VCs) can establish who a participant is and what role they hold, and blockchain can keep a tamper-resistant record of what was agreed. Previous researchers have already proposed each of these technologies for healthcare data sharing. However, through a systematic literature review of 25 primary studies, we have identified that the existing literature treats identity, authority, multi-party approval, purpose, time and the state of the consent as separate conditions. No reviewed study joins them in one decision that is evaluated at every access request, and none proves or tests the decision as a whole.

The primary objective of this study is to propose and develop a trust-oriented authorisation framework termed HALAH, in which patient consent is no longer a stored record but an object that can be evaluated. The consent object carries the identity of the participants, the authority requirements, the guardians named by the patient, the purpose and data scope, the validity period, the lifecycle state and the evidence of every decision. Access is allowed only when the identity check, the approval check, the policy check, the time check and the lifecycle check all pass together, and any failed check gives a refusal that is recorded.

The mechanisms built into HALAH provide the following: (i) a consent model in which consent is represented as an evaluable authorisation object; (ii) verification of the identity and the authority of every participant through DIDs and VCs, so that a valid identity alone does not grant access; (iii) a multi-party authorisation rule in which only verified and distinct approvals from the guardians named by the patient count, and no single party can activate the consent alone; (iv) enforcement of purpose, data scope, validity period and lifecycle state at the time of each request; and (v) an audit ledger that records every decision with the result of each check. Finally, in order to validate the correctness and the security of the proposed framework, software prototyping is chosen as the validation method. The prototype is tested with synthetic patient records, with automated tests, and with attack scenarios in which each check is deliberately bypassed.

CHAPTER 1

INTRODUCTION

1.1 Introduction

Secure and trustworthy data sharing is now needed across organisational boundaries. Modern digital ecosystems involve multiple independent stakeholders, including individuals, healthcare providers, regulatory authorities, researchers, and third-party data processors (Ghafoor et al. 2025; Lomotey, Kumi & Deters 2022; Nguyen et al. 2025). Digital services make collaboration easier, but they also raise a governance question: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain? Healthcare is a clear example of this problem. The increasing digitisation of healthcare information enables patients, healthcare professionals, guardians, researchers, and healthcare organisations to participate in data-sharing processes (Webber et al. 2019; Welzel et al. 2025). At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control.

Traditional access-control architectures are based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms. These approaches can provide effective access control within an organisational boundary, but they become difficult to apply when authorisation decisions involve multiple independent entities. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain. This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, and institutional authorities (Ibrahim et al. 2024; Webber et al. 2019). In these settings, authorisation is a distributed governance problem, not just a check of a user's login and a static permission (Theodorakopoulos, Theodoropoulou & Halkiopoulos 2024).

Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability (Al Mamun, Azam & Gritti 2022; Hellstern et al. 2022; Li, Liu & Shrestha 2026; Nguyen et al. 2025), while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles or authority, and policy-based access-control mechanisms can restrict access to authorised resources. However, an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, or that a subsequent data-access request remains consistent with the conditions originally authorised. Consent must therefore be treated as an active, evaluable part of the authorisation process, not as a static record of permission, extending the dynamic consent perspective (Khalid et al. 2023; Narkhede, Wankhede & Kamble 2025).

1.2 Statement of the Problem

Existing consent-management and decentralised access-control approaches represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created (Jesus & Pandit 2022; Khalid et al. 2023). The relationship between the consent record, the identity of the participants, their authority to act, the applicable policy constraints, and the resulting access decision is frequently treated as separate technical concerns. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information. Even where identity and collective approval have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects identity, authority, multi-party approval, policy, temporal, and lifecycle conditions within a coherent authorisation decision and whose security can be formally and empirically demonstrated. Existing approaches provide important technological components, including decentralised identity and verifiable credentials (Phuyal et al. 2026b; Wu & Zhang 2025), blockchain-based records, multi-party approval mechanisms (Ekholm et al. 2025; Punia et al. 2025; Tan, Chi & Lam 2024), and policy-based access control (Eneh et al. 2026; Khayer et al. 2025; Panagoulias et al. 2026; Román-Martínez et al. 2023), as well as several partial combinations. However, these mechanisms are often investigated independently or integrated primarily at the implementation level. The overarching research question is how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints. The research objectives are operationalised through six corresponding sub-research questions (SRQ1 to SRQ6, referred to as RQ1 to RQ6).

1.3 Research Motivation

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied. Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments (Li et al. 2026b; Ménétrey et al. 2022). Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed. Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems. Future work can therefore investigate how trusted execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.

Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role or permission to participate in a particular decision. Multi-party authorisation concerns whether the required set of independently verified participants has satisfied a defined collective approval condition. Policy compliance concerns whether the requested access is consistent with the authorised purpose and data scope. Time and lifecycle concern whether the consent is still within its validity window and has not expired or been revoked. Together, these

conditions decide whether an authorisation decision has enough basis to be trusted, not only whether access was requested. The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object, C = (I, A, P, T, L, E), that connects the relevant participants, authority requirements, policy constraints, temporal and lifecycle conditions, and evidence associated with an authorisation decision. In C, I is identity and A is authorisation, which holds the guardian set G and the threshold N. P is policy, which covers purpose and data scope. T is time, L is the lifecycle state of the consent, and E is evidence.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient. These four dimensions, RO1 to RO4, collectively define the foundational scope of Multi-Party Patient Consent. RO1 to RO4 are completed with validation and evaluation at the current stage. RO5 adds temporal validity and lifecycle trust, because trust cannot be regarded as permanently established at the moment a consent is created. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state. RO6 concerns formal security assurance and empirical validation. RO5 is in progress, and part of it has already been delivered. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH (History Access Link for Authorised Healthcare) prototype. For RO5, this prototype provides a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation. The remaining formal security assurance and comprehensive empirical evaluation will be conducted in the next stage.

HALAH runs on the Ethereum Sepolia testnet, and the guardian approval rule is currently implemented as N-of-N over the guardian set G. Synthetic healthcare records derived from the Synthea dataset are used to construct representative consent workflows. Security properties are demonstrated through adversarial and negative testing, as well as empirical evaluation using the HALAH prototype and representative healthcare data-sharing scenarios, rather than formal proof. The current stage covers the work delivered so far, while temporal and lifecycle trust, formal security assurance, and comprehensive empirical validation will be developed further in the next stage.

1.4 Decentralised Identity Technology

The framework proposed in this thesis is built on three technologies: decentralised identity, multi-party authorisation and auditable authorisation evidence. This section and the two that follow introduce each of them in turn. Decentralised identity is the first. In a conventional healthcare system, the identity of a doctor, a patient or a guardian is held by one organisation, usually the hospital, and is checked by a login to that organisation. A participant from another organisation cannot be verified without an agreement between the two organisations, and the organisation that holds the account can change or remove it at any time. Decentralised identity moves the identifier and the proof of identity to the participant (Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023). The participant holds an identifier that is not issued by the data holder, and the data holder verifies claims about that participant rather than

looking them up in its own directory. In healthcare, this allows a doctor from one hospital, a guardian who is not a patient of any hospital, and a patient to take part in one consent decision without sharing one identity provider (Shanmugham & Senthilkumar 2026; Wu & Zhang 2025).

1.4.1 Decentralised Identifiers (DIDs)

A decentralised identifier (DID) is a string of the form did:method:identifier that names one participant. The method part states how the identifier is resolved and the last part is unique within that method. A DID is controlled by the holder through a cryptographic key, so the holder can prove control of the identifier by signing with that key, and nobody else can speak for it (Mazzocca et al. 2025). A DID on its own says nothing about the role of its holder. It only states that there is one participant and that this participant can sign. In this thesis, every participant has a DID: the patient, each guardian, the doctor and the issuer of credentials. Full resolution of a DID to its public keys, and the proof that a user controls the DID they present, are treated as work for the next stage (Deng et al. 2024; Yin et al. 2025).

1.4.2 Verifiable Credentials (VCs)

A verifiable credential (VC) is a signed statement, issued by one party about another, that can be checked by a third party without going back to the issuer (Flamini et al. 2024; Mazzocca et al. 2025). A credential names the subject by its DID, states one or more claims, such as the role of doctor or guardian and the organisation, carries a validity period, and is signed by the issuer. The credential is what separates identity from authority: the DID shows who the participant is, and the VC shows what the participant may do. This separation is central to the framework, because a valid identity must never be enough on its own to reach patient data.

1.4.3 Trusted Issuers and Credential Verification

A credential is only as good as its issuer. The framework therefore keeps a registry of trusted issuers, such as a health authority, and a credential is accepted only when its signature recovers to the registered key of an issuer in that registry. Four conditions are checked on every credential: the signature is valid, the issuer is trusted, the subject of the credential is the DID that presented it, and the current time lies within the validity period. A credential also has to carry the role that the step requires, so a guardian credential cannot be used to act as a doctor. In the prototype, one demonstration issuer signs all credentials, and the credential check demonstrates the verification rather than the secrecy of the issuer key.

1.5 Multi-Party Authorisation

Multi-party authorisation is a rule under which a decision needs the agreement of more than one party before it takes effect. In healthcare consent, the parties are the people who must agree before a patient's data can be released: the patient, and for a minor or an incapacitated patient, the guardians (Hagström et al. 2024; Webber et al. 2019). The reviewed literature contains several forms of multi-party approval. Madine et al. (2020) require a regulator and a guardian threshold when the patient is incapacitated, Wu et al. (2022) use a threshold of investigators to admit and revoke records, Zhao and Su (2024) delegate authority through a threshold, Tan, Chi and Lam (2024) let the patient appoint verifiers, and Maruthi and Singh (2025) treat the guardians of an unconscious patient as the approving parties.

In this thesis, multi-party authorisation is defined by two elements that the patient sets when the consent is created: the guardian set G, which lists the participants whose

approval is required, and the threshold N, which is the number of valid approvals needed. An approval counts only when it comes from a member of G, when it is signed by that member, and when that member has not already approved the same consent. An approval from a signer outside G, or a second approval from the same guardian, does not advance the count. In the current prototype, every listed guardian must approve, so N equals the size of G, and the rule has been demonstrated with two guardians.

1.6 The Relationship between Multi-Party Authorisation and Patient Consent

Patient consent and multi-party authorisation are often handled by different parts of a system. The consent is a record of what the patient allowed, and the approval of the guardians is a separate step that happens once, for example at registration (Ekholm et al. 2025) or when a patient is admitted (Wu et al. 2022). Once that step has passed, later requests for data do not look at it again. In this thesis, the two are joined. The guardian set and the threshold are part of the consent object itself, and the approvals that the guardians give are stored with the consent as evidence. A consent with fewer approvals than its threshold stays pending and cannot release any data. A consent that reached its threshold becomes active, and the approvals are checked again whenever a doctor asks for data, together with the identity, policy, time and lifecycle conditions. Multi-party authorisation is therefore not a gate that the consent passes once, but a standing condition that the consent must keep satisfying for as long as it is used.

1.7 Purpose of Using Multi-Party Authorisation in Consent Management

There are three reasons for placing multi-party authorisation inside consent management rather than beside it. The first is that it removes the single point of decision. Where a patient cannot decide alone, no one guardian, and no hospital account, should be able to release the data on their own. The second is that it keeps the approving set under the control of the patient. In the reviewed studies, the parties who must approve are usually chosen by the institution or by a delegate (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024). In the proposed framework, the patient names them when the consent is created, and the system enforces that list. The third is that it makes the approval verifiable after the event. Each approval is a signature over the consent identifier and the guardian identifier, so an auditor can later confirm who approved which consent, and a signature cannot be moved from one consent to another.

1.8 Authorisation Evidence and Auditability

A decision to release patient data must be explainable afterwards. It is not enough to record that access happened; the record must show why it was allowed or refused. The framework treats this as the evidence component E of the consent object. For every request, the result of each check is written down together with the decision, so that a later reader can see whether the requester was verified, whether the approvals were sufficient, whether the purpose and scope were within the consent, whether the consent was in its validity period, and whether its lifecycle state allowed access. Blockchain or other tamper-resistant storage can be used to preserve selected evidence (Andrew et al. 2023; Li, Liu & Shrestha 2026), but in this thesis the blockchain is not the source of trust. Trust comes from the checks themselves; the storage only makes their record harder to alter.

1.8.1 The Audit Ledger

In the prototype, the evidence is kept in an audit ledger. The ledger is an append-only list of events. Each event records the actor, the action, the consent identifier, the time, the result and, for an access decision, the outcome of the five checks. A digest of the key fields of each event is computed and stored with it, so that any later change to a stored event can be detected. The ledger records the creation of a consent, each guardian approval, each state check, each data access and each revocation. Refusals are recorded as well as grants. The auditor interface reads this ledger and presents the decisions in the order in which they were made.

1.9 Consent Management Systems

A consent management system records what a patient has allowed and makes that record available to the systems that hold the data. The simplest systems store a signed form. Dynamic consent systems let the patient change the permission over time and notify the parties affected (Albalwy, Brass & Davies 2021; Khalid et al. 2023). Purpose-based systems tie the permission to a stated purpose, such as treatment or research (Tith et al. 2020), and consent receipts give the patient a readable record of each permission (Jesus & Pandit 2022). More recent systems place the consent on a blockchain so that it cannot be altered quietly, and some of them connect it to an access-control layer (Jaiman & Urovi 2020; Phuyal et al. 2026a; Zhang, Kan & Huang 2022). All of these systems have one thing in common: the consent is treated as a record of a permission. The access decision that follows is made by another component, usually an access-control list or a role check, and that component looks at the consent record only to confirm that it exists.

1.10 Challenges Faced by Current Consent Management Systems

The systematic literature review in Chapter 2 identifies six challenges in the current generation of consent management systems. They are summarised here and stated in full in Chapter 3.

First, consent is represented as a record of permission rather than as an object that can be evaluated, and the few evaluable consent objects carry only some of the conditions that an access decision needs. Second, a valid decentralised identity establishes who a participant is but not what the participant is authorised to do, and authority is checked separately from authentication in only a minority of the reviewed studies. Third, multi-party approval appears as a contingency path, an admission gate or a registration-time co-consent, but not as a standing condition of every access decision with an approving set defined by the patient. Fourth, purpose and data-scope constraints are rarely bound to the same decision as identity, authority and multi-party approval. Fifth, validity periods, lifecycle state and revocation are often enforced on a credential or at registration rather than at the time of each request. Sixth, the authorisation decision as a whole is neither formally proved nor systematically tested.

The first five challenges together mean that the conditions for a trustworthy decision exist but are never joined. The sixth means that, even where they are joined, nobody has shown that the joined decision behaves as intended. This thesis addresses both.

1.11 Research Contribution

1.11.1 Scientific Contribution

The scientific contributions of this research are threefold. First, this research proposes a trust-centric consent model that integrates identity, authority, multi-party approval, and policy constraints into a unified healthcare authorisation framework. Second, this research proposes a multi-party authorisation mechanism that requires approval from

multiple verified participants before granting healthcare data access, where collective consent is required. Third, this research proposes a trust-aware authorisation approach that evaluates identity, authority, collective approval, and policy compliance when determining healthcare data-access permissions.

1.11.2 Social Contribution

The social contributions of this research are also threefold. First, this research aims to help patients and their guardians manage consent for sharing sensitive healthcare information, supporting greater control over healthcare data access. Second, this research aims to support patient privacy by restricting healthcare data access according to authorised purposes and data scopes. Third, this research aims to support transparency and accountability in healthcare data sharing by providing verifiable records of consent activities and access decisions.

1.12 Thesis Plan

This thesis is organised into eleven chapters.

Chapter 1 introduces the research. It states the problem, gives the motivation, introduces the three technologies on which the framework is built, summarises the challenges in current consent management systems, and lists the contributions of the thesis.

Chapter 2 presents the systematic literature review. It defines the six key requirements for trustworthy multi-party consent authorisation, describes the process used to search, select and assess the literature, reviews the 25 primary studies in six streams, compares them against the requirements, and identifies the research gap.

Chapter 3 states the research gap, the main research question, the six sub-research questions and the six research objectives, and shows how they form one integrated problem.

Chapter 4 presents the research methodology, which is design science research, and gives an overview of the proposed solution for each research question.

Chapter 5 presents the research architecture, based on the model-view-controller pattern, and the trust-centric consent model of Research Objective 1, in which consent is represented as the evaluable object $C = (I, A, P, T, L, E)$.

Chapter 6 presents the decentralised identity and authority verification mechanism of Research Objective 2.

Chapter 7 presents the multi-party authorisation mechanism of Research Objective 3.

Chapter 8 presents the policy- and context-aware access control mechanism of Research Objective 4.

Chapter 9 presents the temporal validity and consent lifecycle controls of Research Objective 5.

Chapter 10 presents the formal security assurance and the empirical validation of Research Objective 6, together with the working of the HALAH prototype, the dataset used, the live scenarios, the measured results and the attack scenarios.

Chapter 11 concludes the thesis and sets out the directions for future work.

1.13 Conclusion

This chapter introduced the research. It described the setting in which patient data are shared across organisations, stated the problem that current consent and access-control systems treat consent as a stored record rather than as a condition that is evaluated at

each request, and gave the motivation for a trust-oriented approach in which trust is the outcome of several independently verified conditions. It introduced decentralised identity, multi-party authorisation and auditable authorisation evidence as the three technologies on which the proposed framework is built, summarised the six challenges found in current consent management systems, and listed the scientific and social contributions of the thesis. The next chapter reviews the literature systematically and establishes the gap that this thesis addresses.